

INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha: 16/07/2025
- Entorno : Windows 2007

○ IP-> 192.168.88.147

ÍNDICE

- 1. OBJETIVO Y ALCANCE
- 2. SUMARIO EJECUTIVO
- 3. CLASIFICACIÓN DE VULNERABILIDADES
- 4. VULNERABILIDADES DETECTADAS
- 5. RECOMENDACIONES GENERALES
- 6.- EVIDENCIAS
- 7.- CONCLUSIÓN

OBJETIVO Y ALCANCE

- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows 7** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

SUMARIO EJECUTIVO

- Tras el análisis del sistema Windows 7, se han detectado vulnerabilidades de nivel **crítico, alto, medio y bajo**. Las más críticas permiten la ejecución remota de código, mientras que otras permiten la enumeración de usuarios o la exposición de información sensible.
- El sistema presenta una configuración obsoleta y servicios innecesarios expuestos, lo que incrementa la superficie de ataque.
- Recomendamos tomar medidas correctivas inmediatas sobre los servicios de red activos y establecer políticas más restrictivas en la red para reducir el riesgo global.

CLASIFICACIÓN DE VULNERABILIDADES

- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
 - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
 - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
 - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
 - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.

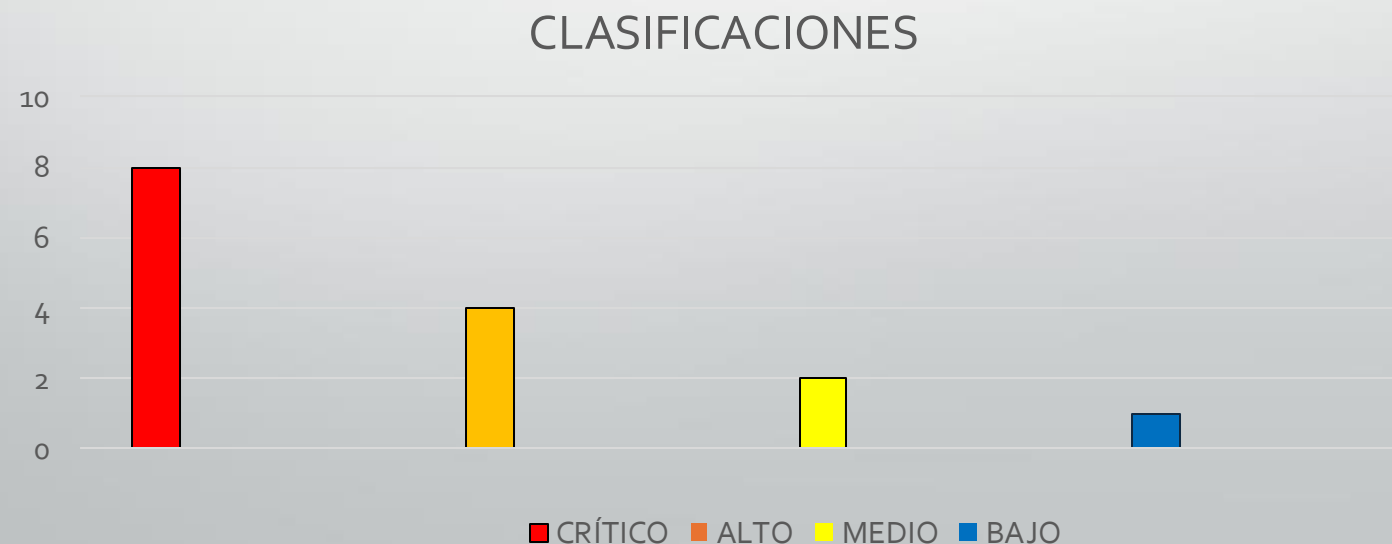
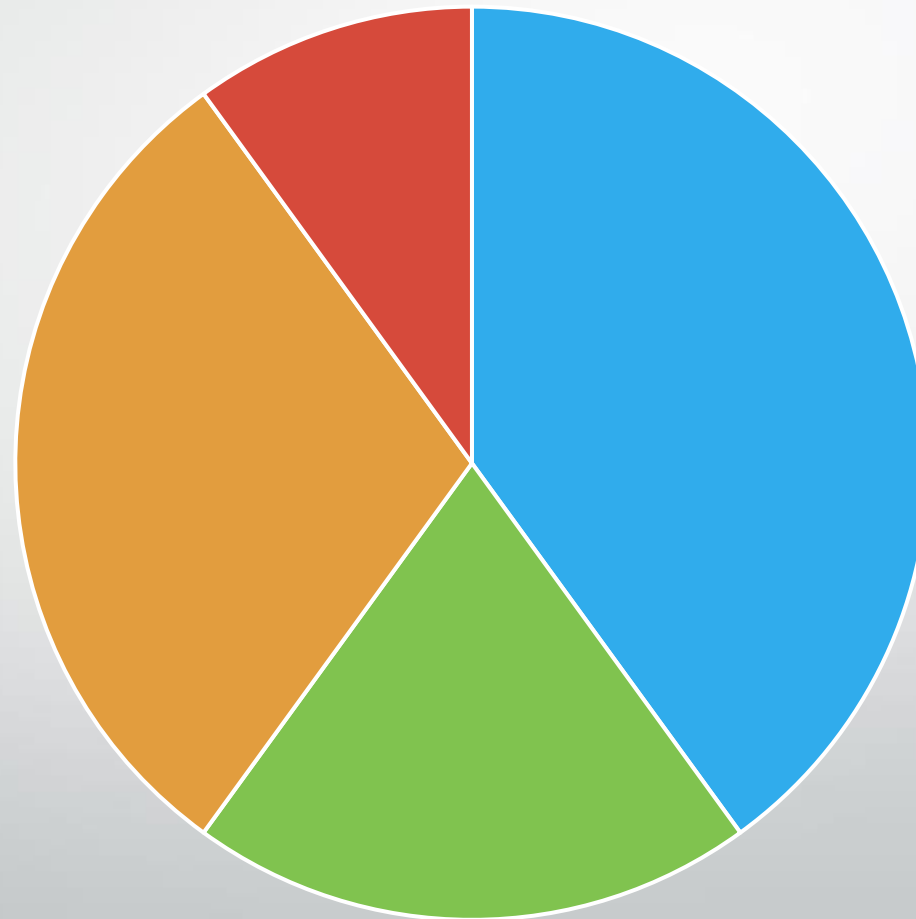


TABLA DE VULNERABILIDADES

Nivel	Puerto	Servicio	Descripción	CVE	Recomendación
Crítico	445	SMB	Este servicio puede ser vulnerable a ejecución remota de código.	CVE-2009-3103	Aplicar parches de seguridad. Deshabilitar SMBv1 si está activo. Restringir acceso por firewall.
Alto	139	NetBIOS	Permite enumeración de recursos compartidos, usuarios y nombres de máquina. Puede ser útil para ataques dirigidos en red interna.	-CVE-2017-0144 -CVE-2020-0796	Deshabilitar NetBIOS si no se utiliza. Filtrar el tráfico por firewall.
Medio	135,49152 - 49157	MSRPC	Múltiples servicios RPC expuestos permiten enumeración del sistema y podrían facilitar ataques como PrintNightmare si no se aplican parches.	CVE-2021-1675	Limitar exposición por red, segmentar servicios, aplicar principio de mínimo privilegio.
Bajo		Sistema operativo	El sistema operativo detectado (Windows 7) ha alcanzado fin de soporte por parte de Microsoft, lo que lo deja expuesto a vulnerabilidades no parcheadas.		Migrar a un sistema con soporte activo, como Windows 10 o 11.

GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445 ■ Puerto 135, 49152-49157 ■ Puerto 139 ■ Sistema Operativo

RECOMENDACIONES

- Se recomiendan medidas correctivas a nivel de servicios, usuarios y red, tales como:
 - Deshabilitar SMBv1 y puertos innecesarios.
 - Aplicar políticas de contraseñas robustas.
 - Limitar accesos administrativos por red.
 - Aplicar segmentación de red y filtrado por firewall.
 - Mantener el sistema actualizado y con parches de seguridad.

EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.

EVIDENCIA N° 1 – Servicio SMB activo

- **Puerto:** 445
- **Nivel de riesgo:** Crítico
- **Servicio:** microsoft-ds
- **Recomendación:**
 - Aplicar parches de seguridad. Deshabilitar SMBv1 si está activo. Restringir acceso por firewall.
- **Descripción:**
 - Se observa el puerto 445 abierto con el servicio microsoft-ds activo en el host . Este servicio corresponde al protocolo SMB, que en sistemas Windows 7 sin parches puede ser vulnerable a ejecución remota de código (CVE-2009-3103). Esta configuración representa una amenaza crítica si no se restringe o actualiza.

```
PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 00:0C:29:0A:64:39 (VMware)

Host script results:
| smb-protocols:
|   dialects:
|     NT LM 0.12 (SMBv1) [dangerous, but default]
|     2:0:2
|     2:1:0
```

```
Anonymous login successful
```

Sharename	Type	Comment
Reconnecting with SMB1 for workgroup listing.		
do_connect: Connection to 192.168.88.147 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)		
Unable to connect with SMB1 -- no workgroup available		

EVIDENCIA N° 2 – Servicio NetBIOS expuesto

- Puerto: 139
- Nivel de riesgo: Alto
- Servicio: netbios-ssn
- Recomendación:
 - Deshabilitar NetBIOS si no se utiliza. Filtrar el tráfico por firewall.
- Descripción:
 - Se detecta el puerto 139 abierto, correspondiente al servicio NetBIOS. Aunque es habitual en sistemas Windows antiguos, su exposición permite enumeración de usuarios, recursos compartidos y nombres de host, lo que facilita el reconocimiento por parte de un atacante.

```
===== ( Enumerating Workgroup/Domain on 192.168.88.147 ) =====
[+] Got domain/workgroup name: WORKGROUP

===== ( Nbtstat Information for 192.168.88.147 ) =====

Looking up status of 192.168.88.147
THUNDERCATS <20> - M <ACTIVE> File Server Service
THUNDERCATS <00> - M <ACTIVE> Workstation Service
WORKGROUP <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
WORKGROUP <1e> - <GROUP> M <ACTIVE> Browser Service Elections
WORKGROUP <1d> - M <ACTIVE> Master Browser
.. _MSBROWSE_ <01> - <GROUP> M <ACTIVE> Master Browser

MAC Address = 00-0C-29-0A-64-39

===== ( Session Check on 192.168.88.147 ) =====

[+] Server 192.168.88.147 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.88.147 ) =====

do_cmd: Could not initialise lsarpc. Error was NT_STATUS_ACCESS_DENIED
[+] Can't determine if host is part of domain or part of a workgroup
```

EVIDENCIA N° 3 – Servicios RPC múltiples expuestos

- **Puertos:** 135, 49152–49157
- **Nivel de riesgo:** Medio
- **Servicio:** msrpc
- **Recomendación:**
 - Limitar exposición por red, segmentar servicios, aplicar principio de mínimo privilegio.
- **Descripción:**
 - El escaneo detecta múltiples puertos abiertos correspondientes a Microsoft Windows RPC (135 y rango 49152–49157). Esta configuración puede permitir la enumeración del sistema y sugiere exposición innecesaria a ataques de lateralización como Print Spooler (CVE-2021-1675).

```
192.168.88.147:135 - 0b6edbf8-4a24-4fc6-8a23-942b1eca65d1 v1.0 LRPC (spoolss) [Spooler function endpoint]
192.168.88.147:135 - ae33069b-a2a8-46ee-a235-ddfd339be281 v1.0 LRPC (spoolss) [Spooler base remote object endpoint]
192.168.88.147:135 - 4a452661-8290-4b36-8fbc-7f4093a94978 v1.0 LRPC (spoolss) [Spooler function endpoint]
```

EVIDENCIA N° 4 – Sistema operativo sin soporte

- **OS detectado:** Windows 7
- **Nivel de riesgo:** Bajo
- **Recomendación:**
 - Migrar a un sistema con soporte activo, como Windows 10 o 11.
- **Descripción:**
 - El sistema operativo identificado es Windows 7. Este sistema se encuentra fuera del soporte oficial de Microsoft desde enero de 2020, por lo que ya no recibe parches de seguridad, lo que aumenta el riesgo de explotación por vulnerabilidades conocidas.

Running: Microsoft Windows 2008|7|Vista|8.1

OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista

OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1

CONCLUSIÓN

- El análisis de seguridad realizado sobre el sistema **Windows 7** ha permitido identificar varios servicios de red expuestos que, en su conjunto, incrementan la superficie de ataque del entorno auditado.
- La detección del servicio **SMBv2 activo en el puerto 445**, combinado con la presencia de múltiples puertos asociados a **MSRPC**, la exposición de **NetBIOS (puerto 139)** y la utilización de un **sistema operativo sin soporte oficial**, representan un riesgo considerable frente a ataques internos o automatizados.
- Se recomienda proceder a la **actualización del sistema operativo a una versión con soporte vigente**, limitar la exposición innecesaria de servicios mediante segmentación y firewall, y establecer un plan de mantenimiento y revisión periódica de la postura de seguridad del entorno.